

Ledningens genomgång

Syfte

- Genomgång av PillMedTech:s informationssäkerhetsmognad
- Hur ser det ut i dagsläget?

Innehåll

- Vad är mognadsdialogen
- Mognadsdialogen resultat & motivering
- Vad som görs bra i nuläget
- Förbättringsförslag
- Affärsnytta
- Hur framtiden ser ut

Riskhantering

Infoklassning

Incidenthantering

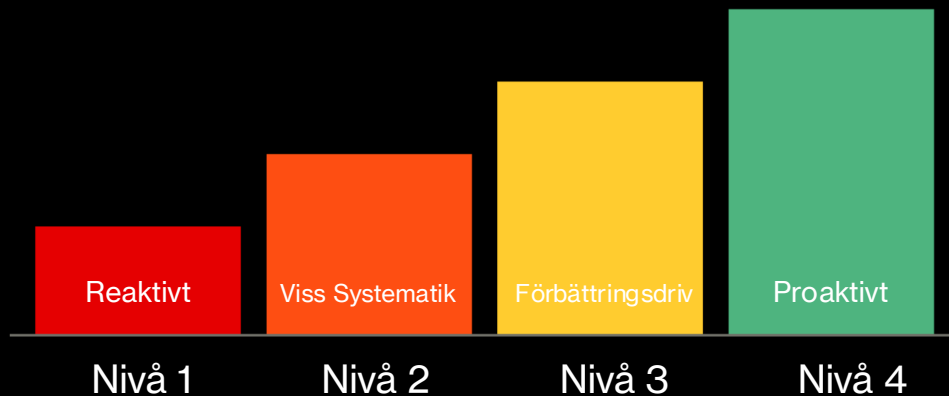
Uppföljning

Kompetens

Upphandling

Arbetssätt Tillämpning Resultat

Följa upp, lära & förbättra



Vad är Mognadsdialogen

- Verktyg från MSB
- Bedömer Mognad
- 6 kategorier
- 4 Kriterier
- Fyra olika Nivåer
- Grunden till Förbättringar

PillMedTech:s Mognad

Nivå 4 Proaktiva						
Nivå 3 Förbättringsdriv						
Nivå 2 Viss Systematik						
Nivå 1 Reaktiva						
	Risk- hantering	Info- klassning	Incident- hantering	Upp- handling	Kompetens	Uppföljning

Riskhantering

- Arbetssätt **Nivå 1**: Saknar arbetssätt för riskhantering, ingen aktiv bedömning, analys, övervakning inom risk.
- Tillämpning **Nivå 1**: Ingen gemensam metod/rutin för rapportering.
- Resultat **Nivå 1**: Enstaka mål utan insamling av resultat.
- Följa upp lära & förbättra **Nivå 1**: Brist på riskhantering har identifierats av Göran Rubens.



	Nivå 1	Nivå 2
Kännetecken kultur	Saknar förståelse för risker	Oj, mer jobb
Arbetssätt	Saknar i huvudsak medvetet valda arbetssätt inom riskhantering - identifiering, analys, behandling, övervakning, riskuppföljning	Har medvetet valt arbetssätt och metod för riskanalys, men saknar i övrigt samordning inom riskhantering. Har risknivåer men nivåerna är inte tydliga vad de innebär i praktiken.
Tillämpning	Hanterar risker reaktivt, ad hoc. Dokumenterar sällan med en gemensam metod. Resonerar om risker när nåt har hänt. Åtgärder genomförs utifrån "köper in", men överväger inte om investeringen är rätt. Känslomässiga beslut dominerar.	Riskanalyser görs i begränsad omfattning. Få efterfrågar riskanalyser. Oklart NÄR de ska göras. Enstaka personer har kompetens att leda riskanalyser. Ledningen har låg insikt om riskhantering. Beslutar att åtgärda risker utifrån begränsat beslutsunderlag och beslut saknas när risker accepteras.
Resultat	Saknar mål med riskhanteringen. Inga resultat samlas in och jämförs över tid.	Enstaka mål med riskhanteringen. Svag koppling mellan riskanalys och resultat.
Följa upp, lära och förbättra	Har hänt att man pratat om hur man arbetar men brister i att omsätta det till lärande och förbättring.	Följer upp och förbättrar arbetssättet för riskanalys. Tar inte lärdom, återanvänder inte genomförda riskanalyser. Saknar överblick över alla analyserade risker.

Incidenthantering

- Arbetssätt **Nivå 1**: Inga tydliga arbetssätt för rapportera eller hantera tidigare incidenter
- Tillämpning **Nivå 2**: Viktiga rapporteras inte alltid & analys när det har hänt.
- Resultat **Nivå 1**: Svag koppling med att incidenter har skett och minskad risk för upprepning.
- Följa upp lära & förbättra **Nivå 1**: Utreder inte incidenter, löser snabbt och tar in konsulter utan att säkra en permanent förbättring.



	Nivå 1	Nivå 2
Kännetecken kultur	Snabba lösningar premieras	Få inrapporterade = bra
Arbetssätt	Saknar tydliga arbetssätt för att rapportera eller hantera inrapporterade incidenter och utreda dessa.	Har tydliga arbetssätt för hur incidenter ska rapporteras och åtgärdas.
Tillämpning	Rapporterar incidenter utifrån personligt engagemang. Resonerar om incidenter när nåt hänt.	Otydligt vad som ÄR en incident, dvs viktiga incidenter rapporteras inte alltid. Analyserar inte grundorsakerna till incidenter utan tar enklaste lösningen (kategorin styr).
Resultat	Negativa händelser upprepas lätt eftersom överblick saknas. Incidenter upprepas. Få incidenter rapporteras vilket tolkas positivt.	Svag koppling mellan incidenter och minskad risk för upprepning. Mäter antalet incidenter. Ofta frustration av att infosäk inte fångas upp via andra rapporterade avvikelser.
Följa upp, lära och förbättra	Utreder inte utan löser snabbt och "köper in", utan att veta det blir rätt.	Man löser "problemet". Följer upp antalet rapporter och prioriterar uppmuntrar att rapportera fler. Har mindre fokus på att skapa effektiv hantering.

Infoklassning

- Arbetssätt **Nivå 1**: Har inga medvetet valda arbetssätt för klassifiering av information
- Tillämpa **Nivå 2**: Implementerat säkerhetsnycklar
- Resultat **Nivå 1**: Identifieras för lite och arbetar inte med resultaten som samlats in.
- Följa upp lära & förbättra **Nivå 1**: Förbättringar har bara skett enstaka gånger på grund av personalens frustration.



	Nivå 1	Nivå 2
Kännetecken kultur	Information, vad då?	Informationen behöver skyddas
Arbetssätt	Saknar medvetet valda arbetssätt för att identifiera och värdera information. Enstaka arbetssätt finns men hänger inte ihop, värderar inte informationen.	Har några medvetet valda arbetssätt för att identifiera, värdera information samt att införa säkerhetsåtgärder. De är inte samordnade. Har klassningsmodell men nivåerna är inte tydliga vad de innebär i praktiken.
Tillämpas	Medvetenhet finns om att informationen måste hanteras utifrån olika lagkrav. Värderingen av information har fokus på it-systemen. Betoning på konfidentialitet. It anses var ansvarig för informationen.	Använder klassningsmodellen i liten skala eller har påbörjat arbetet där behov uppstår. Stort personberoende. Klassningen styr inte alltid val av säkerhetsåtgärder. Betoning på konfidentialitet och tillgänglighet. Ansvar för informationen utgår delvis från informationsägarers krav.
Resultat	Svag koppling mellan säkerhetsåtgärder (i praktiken) och informationens värde. Mål saknas.	Har identifierat, värderat information i liten omfattning. Införda säkerhetsåtgärder har viss koppling till resultatet av klassningen. Enstaka mål finns.
Följa upp, lära och förbättra	Pratas mycket och man är frustrerad. Har hänt att man följt upp som kan leda till enstaka lärande och förbättring.	Förbättrar arbetssätten så att metoden för värderingen av informationen kan ske effektivare. Införda säkerhetsåtgärder utvärderas sporadiskt med fokus på följsamhet till rutinen.

Upphandling

- Arbetssätt **Nivå 2**: Det finns arbetssätt om upphandlingsprocessen. Infosäk är inget uttalat fokus. Policy tar upp lite.
- Tillämpning **Nivå 1**: Fokus på kostnader istället för infosäk.
- Resultat **Nivå 1**: Inga krav på uppföljning av avtal & inga mål
- Följa upp lära & förbättra **Nivå 1**: Svårt att följa upp och se lärande. Ingen dokumentation, inga klagomål just nu.



	Nivå 1	Nivå 2
Kännetecken kultur	Naiv	Godtrogen
Arbetssätt	Saknar arbetssätt för att ställa krav på informationssäkerhet vid upphandlingar.	Har beslutade arbetssätt om hur upphandlingsprocessen ska ske, men ottydligt hur/när infosäk ska beaktas. Enstaka krav ställs på infosäk under avtalsperioden.
Tillämpning	Ad hoc, den som skriker högst medverkar i upphandlingsprocessen. Har huvudsakligen fokus på kostnader.	Infosäk medverkar i inledningsskedet och vissa säkerhetskrav tas fram. Ställer några infosäkrav i avtalen med leverantören. Uppföljning av leverantörer görs huvudsakligen på SLA/tillgänglighet.
Resultat	Har inte några krav på uppföljning i avtalen. Saknar mål och resultat.	Bevis saknas att informationen skyddas tillräckligt. Leverantörens egen uppföljning kan rapporteras in som bevis exempelvis it-incidenter och SLA. Enstaka mål.
Följa upp, lära och förbättra	Har hänt att man följer upp arbetssätten. Svårt att omsätta till lärande och förbättring.	Följer upp enstaka genomförda upphandlingar för att förbättra processen. Viss dialog om hur leverantörens uppföljning kan förbättras.

Kompetens



- Arbetssätt **Nivå 1**: Inga interna utbildningar

- Tillämpning **Nivå 1**: Diskussion om utbildning för enstaka chefer men inga utbildningar har genomförts eller köpts in.

- Resultat **Nivå 1**: Inga klagomål från ledning och inga utbildningar har genomförts.

- Följa upp lära & förbättra **Nivå 1**: Diskussioner har skett i liten skala om grundläggande utbildningar men ingen förbättring har gjorts.

	Nivå 1	Nivå 2
Kännetecken kultur	Okunnig	Informerad
Arbetssätt	Inga utbildningar finns framtagna. Köper in.	Enstaka arbetssätt för utbildning och träning finns.
Tillämpning	Informerar om viktiga områden vid behov. Enstaka utbildningar genomförs, köps in.	Insikt finns om utbildningsbehov. Enkla standardutbildning genomförs ex nyanställda. Utbildningsplanen följs inte eller ändras ofta. Få personer kan utbilda.
Resultat	Nöjd med att utbildningen är genomförd.	Effekten är oklar. Resultaten har fokus på antalet att utbildningstillfällen ökar.
Följa upp, lära och förbättra	Pratar, vi borde göra detta regelbundet.	Följer upp hur utbildningarnas praktiska delar, för att underlätta att flera ska gå utbildningen.

Uppföljning



- Arbetssätt **Nivå 1**: Inget genomtänkt arbetssätt och få egenkontroller

- Tillämpning **Nivå 1**: Enstaka egenkontroller. Exempelvis antivirus.

- Resultat **Nivå 1**: Enstaka rapporter utan tydliga resultat.

- Följa upp lära & förbättra **Nivå 1**: Egenkontroller diskuteras sällan och större problem löses enkelt.

	Nivå 1	Nivå 2
Kultur, kännetecken	Utan spaning ingen aning	Göra saker
Arbetssätt	Saknar arbetssätt för uppföljning förutom enstaka viktiga egenkontroller.	Några olika arbetssätt för uppföljning finns men de brister i samordning och systematik. Har enstaka planer för uppföljning.
Tillämpning	Enstaka egenkontroller genomförs. I övrigt utifrån egna personers initiativ. Granskningar köps in eller genomförs av en=personberoende.	Planerna genomförs inte alltid. Enstaka interrevisorer, eller granskningar görs, men brister i efterarbetet. Kompetens och resurserbrist.
Resultat	Enstaka rapporter kan sammanställas men inga specifika resultat finns.	Enstaka resultat sammanställs men oklart om resultatet ger bättre informationssäkerhet. Har fokus på att vi GÖR uppföljning och följa planen.
Följa upp, lära och förbättra	Egenkontroller diskuteras och större problem fixas till på enklaste sätt.	Följer upp några arbetssätten vissa resultat av uppföljningen som leder till enstaka förbättringar.

PillMedTech:s Styrkor

- Säkerhetskort och Åtkomstnivåer
- Medvetenhet I Upphandling (Policy)
- Incidenthantering (Nattlig Server-backup)



#1

Skapa bättre och säkrare arbetsrutiner hos personal & ledningen genom utbildning

- Nuläget: Personal och ledning saknar förståelse för informationssäkerhet och saknar arbetsrutiner
- Att ta fram och införa en grundläggande och digital utbildning
 1. Lösenordshantering
 2. Informationsklassning
 3. Incidenthantering
 4. Incidentrapportering
 5. Systematiska arbetssätt
- Obligatorisk, kompletteras årligen
- Ansvarig: Göran Rubens
- Höja medvetenheten om säkerhet, minska sannolikheten för mänskliga misstag och stärka säkerhetskulturen i företaget.
- Affärsnytta: Minskade framtida förluster och ökad produktivitet.

#2

Identifiera, minimera dagens & framtidens risker samt deras konsekvenser

- Nuläget: Riskrelaterat arbete sker endast reaktivt. Organisationen saknar kunskap om potentiella risker och deras konsekvenser, samt saknar rutiner och dokumentation.
- Genomför årlig riskanalys med stöd av MSB:s metod.
- Skapa en riskhanteringsprocess för personalen.
- Dokumentera inträffade incidenter och beslutade åtgärder, samt tydliggöra ansvaret för respektive område.
- Ansvarig: Göran Rubens
- Minskad chans för allvarliga incidenter, och om de inträffar, begränsas skadorna snabbt. Detta sparar tid och pengar.

#3

Rapportera, hantera och lär från tidigare incidenter

- Saknar tydliga rutiner incidenthantering och dokumentation
- Skapa tydlig incidenthanteringsprocess med rutiner för rapportering, utredning och uppföljning
- Föra dokumentation om tidigare incidenter
- Årlig utvärdering av incidenthanteringsprocessen
- Ansvarig: Göran Rubens
- Snabba åtgärder, Tryggare personal.
- Affärsnytta: Total produktion ökar (mindre downtime)

Affärsnytta

- Varför ska vi prioritera detta?
- Detta behövs göras så tidigt som möjligt, med tanke på hur omvärlden ser ut just nu när krig och kris råder världen över, för att skydda mot framtida och nutida hot innan det sker en incident. Genom att kunna uppnå kraven från ISO standarderna och NIS2 kan detta förhindras.
- Vad kan PillMedTech tjäna på att göra detta?
- Detta leder till ökat rykte för PillMedTech som företag och som producent av vacciner och mediciner till butiker och apotek runt om i landet. Det leder också till ökad produktionssäkerhet vilket leder till mindre stopp i produktionen och på så sätt spara pengar på underhåll och tjäna på mera produkter tillverkade.

Framtiden

- NIS2 är ett EU direktiv som gäller från januari 2026. Den ställer höga information & Cybersäkerhet krav på samhällsviktiga organisationer och företag, PMT inkluderat. Detta blir lag, är inte en fråga OM, snarare HUR vi ska uppfylla dessa krav.
- Internationell erkänd standard, ISO 27001 Certifiering är ett bra sätt att uppnå många av NIS 2 kraven.

Sammanfattning

- Nuläget

Mognadsnivå 1, Rutiner & Systematiska arbetssätt, Styrkor

- Förbättringsförslag

Utbildning, Riskhanteringsprocess, Incidenthanteringsprocess

- Affärsnytta

Minskad risk, Färre driftstopp, Höjt Kundförtroende

- Framtiden

NIS 2, ISO 27001

Källor

- 2-1 PillMedTech_Version_1-4, Infosäkpolicy PillMedtech_fastställd
- <https://www.msb.se/sv/amnesomraden/informationssakerhet-cybersakerhet-och-sakra-kommunikationer/arbeta-systematiskt-med-informationssakerhet-och-cybersakerhet/mognadsdialogen/>